ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

VMware ESXi 8 (vSphere Hypervisor) · Component type: **Host Device (HDR) - bare-metal hypervisor** · Target SL = SL 3

Where to work	Manage via **vCenter** (SSO roles) or the **ESXi Host Client** (HTTPS 443); **DCUI** (console); **PowerCLI** (`Get-VMHost`, `Get-AdvancedSetting`) and **ESXCLI**. SSH / ESXi Shell are **off by default**. Baseline against the **DISA vSphere ESXi 8 STIG** + **vSphere Security Configuration Guide**.
Interfaces / ports	HTTPS **443** (API/Host Client); VMkernel **902**; **SSH 22** (disabled); vMotion 8000; vSAN; syslog 514; CIM 5989 (disable). Isolate the management VMkernel on its own VLAN.
Notes	HDR (bare-metal hypervisor). Confirm `esxcli system version get` (ESXi 8.0 Ux) and **Lockdown Mode** (Normal/Strict). Verify effective settings via PowerCLI advanced settings.
How to read	Default read-only (PowerCLI/ESXCLI get, Host Client view). Native how-to + external-tool validation + pass. Write/exploit tools = isolated env + written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	Management authenticated via vCenter SSO / host local accounts; **SSH & ESXi Shell disabled** (`Get-VMHostService` -> TSM/TSM-SSH Stopped, Policy off); DCUI restricted; **Lockdown Mode** enabled. **Test:** no anonymous host access; SSH refused. **Ext. tools:** PowerCLI (`Get-VMHostService`); STIG/SCAP scan; Nmap (22 closed).	All host access authenticates; SSH/Shell off; lockdown mode on.	HDR.
SR/CR 1.2	Software process / device identification	Confirm the host has a unique managed identity in vCenter and services/agents authenticate; VMkernel management interface is identified and isolated; no anonymous API access. **Ext. tools:** PowerCLI Get-VMHost; vCenter inventory review.	Host uniquely identified/managed; services authenticate.	
SR/CR 1.3	Account management	Minimal local users; join to AD / use vCenter for identity; manage the root password (vault/LAPS-equivalent); remove unused local accounts. **Ext. tools:** PowerCLI/Host Client user review; STIG scan.	Named least-priv identities; root managed; no unused local accounts.	
SR/CR 1.4	Identifier management	Confirm named admin accounts (vCenter SSO / AD), no shared root use, **Exception Users** list minimized, and the local root password managed/rotated; lifecycle via SSO. **Ext. tools:** PowerCLI Get-VMHostAccount; vCenter SSO user review.	Unique identifiers; shared root minimized; managed lifecycle.	
SR/CR 1.5	Authenticator management	Password quality: `Security.PasswordQualityControl` (e.g. `similar=deny retry=3 min=disabled,disabled,disabled,7,7`); password history `Security.PasswordHistory`; verify via advanced settings. **Ext. tools:** `Get-AdvancedSetting -Name Security.Password*`; STIG scan.	Strong password quality + history enforced.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm ESXi/vCenter certificates are CA-signed (VMCA subordinate or enterprise CA), valid, and not the default self-signed; management TLS uses trusted certs. **Ext. tools:** Browser cert / openssl on 443; vCenter cert management review.	CA-signed, valid certificates; default self-signed replaced.	
SR/CR 1.9	Strength of public key auth	Confirm strong TLS (1.2/1.3 only) and ciphers on host/management interfaces; ESXi SSH (if enabled) uses strong keys/ciphers; weak protocols disabled. **Ext. tools:** testssl.sh :443; ssh-audit (if SSH enabled).	Strong TLS/SSH crypto; weak protocols disabled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.10	Authenticator feedback	Confirm DCUI/host client/SSH mask password entry; DCUI access restricted; login banners do not leak host detail before auth. **Ext. tools:** Visual (DCUI / host client); Annotations.WelcomeMessage review.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Account lockout: `Security.AccountLockFailures` (e.g. 3) + `Security.AccountUnlockTime` (e.g. 900). Verify advanced settings. **Ext. tools:** `Get-AdvancedSetting -Name Security.Account*`; STIG scan.	Lockout after few failed attempts for a set time.	
SR/CR 1.12	System use notification	Login banner: `Annotations.WelcomeMessage` (DCUI/Host Client) and `Config.Etc.issue` (SSH) set to the approved notice. **Ext. tools:** `Get-AdvancedSetting -Name Annotations.WelcomeMessage`; STIG scan.	Approved banner displayed at DCUI/Host Client/SSH.	
SR 1.13	Access via untrusted networks	Isolate the management VMkernel (dedicated VLAN); Lockdown Mode; ESXi firewall restricts mgmt sources; no direct host mgmt from untrusted networks. **Ext. tools:** Nmap (443/902 reachability by segment); firewall review.	Host mgmt reachable only from the isolated mgmt network.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	vCenter **roles/permissions** least privilege; Lockdown-Mode Exception Users minimal; DCUI.Access limited. **Test:** a low-priv vCenter role cannot change host config. **Ext. tools:** PowerCLI (`Get-VIPermission`); STIG scan.	Least privilege via roles; exception users minimal.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control host removable/local media: restrict USB passthrough, datastore uploads, and VM device connect/disconnect by operators; no unmanaged media introduces images. **Ext. tools:** PowerCLI (VM USB/device review); datastore permission review.	Removable/media use on the host controlled.	
SR/HDR 2.4	Mobile code	Enforce **execInstalledOnly** (VMkernel.Boot.execInstalledOnly=TRUE) so only VIB-signed binaries run; set VIB **acceptance level** to PartnerSupported+ ; no untrusted code executes on the host. **Ext. tools:** PowerCLI Get-AdvancedSetting execInstalledOnly; esxcli software acceptance get.	Only signed/installed code runs; untrusted mobile code blocked.	HDR-specific.
SR/CR 2.5	Session lock / timeouts	Shell/DCUI timeouts: `UserVars.ESXiShellInteractiveTimeOut`, `UserVars.ESXiShellTimeOut`, `UserVars.DcuiTimeOut` (non-zero); Host Client session timeout. **Ext. tools:** `Get-AdvancedSetting -Name UserVars.*TimeOut`; STIG scan.	Idle shell/DCUI/Host-Client sessions time out.	
SR/CR 2.6	Remote session termination	Confirm session timeouts: **ESXiShellInteractiveTimeOut** / **ESXiShellTimeOut**, host client / API idle timeout, and DCUI.Access limits; sessions terminable via vCenter. **Ext. tools:** PowerCLI Get-AdvancedSetting (ShellTimeOut); session review.	Management/shell sessions time out and are terminable.	
SR/CR 2.7	Concurrent session control	Limit concurrent host client / API sessions and shell logins; monitor active sessions via vCenter; enforce lockdown so direct host sessions are constrained. **Ext. tools:** vCenter session monitor; lockdown-mode review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Remote **syslog**: `Syslog.global.logHost` set to the SIEM (ssl://); enable audit records (vSphere audit); persistent scratch/log location. **Test:** host events reach the SIEM. **Ext. tools:** `Get-AdvancedSetting -Name Syslog.global.logHost`; SIEM check.	Host events + audit records forwarded to remote syslog/SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm host logs are sized and forwarded: persistent scratch/log location set and **Syslog.global.logHost** ships to the SIEM so events survive host reboot and local capacity. **Ext. tools:** PowerCLI Get-AdvancedSetting Syslog.global.logHost; SIEM retention.	Logs persistent and forwarded/retained beyond local capacity.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/syslog collector alerts on loss of host log forwarding; host continues local logging to persistent store. **Ext. tools:** SIEM agent-health / syslog gap alerting.	Defined response to audit failure; forwarding-loss alerting.	
SR/CR 2.11	Timestamps	NTP configured & running: `esxcli system ntp get` / `Get-VMHostNtpServer` to authorized sources; NTP service policy = on. **Ext. tools:** `esxcli system ntp get`; Wireshark (NTP).	Accurate synced time; consistent event timestamps.	
SR/CR 2.12	Non-repudiation	Confirm attributable admin actions: named SSO accounts, vCenter events/tasks logged per user, shell access via Exception Users only and audited. **Ext. tools:** vCenter Events/Tasks by user; shell.log review.	Admin actions attributable to unique users.	
HDR 2.13	Physical / diagnostic interfaces	Control host physical/diagnostic access: **ESXi Shell** and **SSH** disabled (start policy off), **DCUI** restricted, shell/console timeouts set; unused management interfaces off. **Ext. tools:** PowerCLI (Get-VMHostService: TSM-SSH/TSM off); ESXiShellTimeOut review.	Shell/SSH/DCUI controlled and timed out; diagnostic access restricted.	HDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1	Communication integrity	Confirm management and vMotion/storage traffic integrity: management on an isolated VLAN, encrypted vMotion enabled, TLS on all management channels; no cleartext management. **Ext. tools:** PowerCLI (vMotion encryption); Wireshark (mgmt VLAN).	Management/vMotion traffic integrity-protected; isolated.	
SR/HDR 3.2	Protection from malicious code	VIB acceptance level Partner/VMware-signed only (`esxcli software acceptance get` -> not CommunitySupported); **execInstalledOnly** (`VMkernel.Boot.execInstalledOnly = true`); Secure Boot enforces signed VIBs. **Ext. tools:** `esxcli software acceptance get`; STIG scan.	Only signed VIBs run; execInstalledOnly on; no CommunitySupported.	HDR-specific.
SR/CR 3.3	Security functionality verification	Re-verify hardening after change against the **vSphere Security Configuration Guide** (SCG) using **Host Profiles** compliance and a PowerCLI audit script; confirm no drift. **Ext. tools:** Host Profile compliance; PowerCLI SCG audit; DISA vSphere STIG.	Configuration matches the SCG/STIG baseline after change.	
SR/CR 3.4	Software & information integrity	**UEFI Secure Boot** + **TPM 2.0** host attestation (`esxcli system settings encryption get`, vCenter attestation status); signed image; verify `esxcli software vib signature verify`. **Ext. tools:** vCenter attestation view; STIG scan.	Secure Boot + TPM attestation pass; image integrity verified.	HDR-specific.
SR/CR 3.5	Input validation	Confirm host management/API robustness to malformed input; keep the host patched (VMSA advisories) since input-validation flaws are addressed via updates; fuzz management API in a lab only. **Ext. tools:** VMSA/patch review; API fuzz (ISOLATED).	Patched against known input-validation CVEs; no crash on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm graceful failure: core dumps directed to a protected coredump partition/server, no sensitive data in logs, host services recover; HA handles host failure. **Ext. tools:** esxcli system coredump review; log inspection.	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm management sessions are integrity-protected (TLS), replay-resistant; SSH (if used) protects sessions; old sessions cannot be replayed. **Ext. tools:** Wireshark (TLS session); session-token review.	Management sessions integrity-protected against replay/hijack.	
SR/CR 3.9	Protection of audit information	Protect host logs: forward to a write-once SIEM, restrict shell/datastore access to logs, so local tampering cannot erase the audit trail. **Ext. tools:** SIEM immutability; log permission review.	Audit records protected from unauthorized modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
HDR 3.10	Support for updates	Patch via **vLCM** / baselines with signed images; verify version/patch level and a rollback (revert to prior image). **Ext. tools:** vLCM compliance; `esxcli software profile get`	Signed updates applied; rollback available.	HDR-specific.
HDR 3.11	Physical tamper resistance/detection	Confirm hardware root of trust: **TPM 2.0** present, **UEFI Secure Boot** on with ESXi attestation in vCenter (Trust Authority), chassis in a locked data center; boot order locked. **Ext. tools:** vCenter host attestation status; TPM/Secure Boot in BIOS; physical inspection.	TPM + Secure Boot attested; chassis controlled.	HDR-specific.
HDR 3.12	Provisioning product-supplier roots of trust	Confirm only VMware-signed code boots/runs: **Secure Boot** validates the VMware-signed bootloader/kernel/VIBs; unsigned VIBs rejected (execInstalledOnly + acceptance level). **Ext. tools:** Secure Boot state; esxcli software vib signature check.	Supplier root of trust intact; only signed VIBs/boot code run.	HDR-specific.
HDR 3.13	Provisioning asset-owner roots of trust	Confirm asset-owner trust anchors: vSphere **Trust Authority** attestation cluster owned by the asset owner, owner-managed KMS for VM/vSAN encryption keys. **Ext. tools:** Trust Authority config; KMS (owner key provider) review.	Asset-owner attestation and key management provisioned.	HDR-specific.
HDR 3.14	Integrity of the boot process	Confirm integrity of the boot process — only signed/verified firmware boots (device requirement). **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.4** above (shared steps); confirm this requirement individually and adjudicate it separately.	Integrity of the boot process verified individually.	HDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**VM encryption** + **encrypted vMotion** (Required) via a KMS/native key provider; TLS for management. Verify `Get-VMHost | Get-View` encryption mode / vMotion encryption = required. **Ext. tools:** PowerCLI encryption status; STIG scan.	VM data + vMotion encrypted; management over TLS.	
SR/CR 4.2	Information persistence	On decommission/reuse, sanitize: crypto-erase encrypted VMs/vSAN (destroy KMS keys), wipe datastores, remove host from inventory and reset; confirm no recoverable VM data/keys. **Ext. tools:** KMS key destroy; datastore wipe; verify.	Sensitive VM data/keys purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	TLS 1.2/1.3 only (`UserVars.ESXiVPsDisabledProtocols` disables TLS1.0/1.1); strong ciphers; verify. **Ext. tools:** sslscan `:443`; STIG scan.	TLS 1.2/1.3 + strong ciphers; legacy TLS disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1	Network segmentation	**ESXi firewall** enabled with least services (`esxcli network firewall get` / `Get-VMHostFirewallException`); isolate mgmt/vMotion/storage VLANs; restrict allowed IP ranges per service. **Ext. tools:** Nmap (open services by segment); `esxcli network firewall ruleset list`	Firewall on with least services; networks segmented; sources restricted.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	N/A at the hypervisor: the bare-metal host provides no general-purpose person-to-person communications; management is single-purpose and restricted. **Ext. tools:** Confirm no general-purpose apps/services on the host.	No person-to-person comms on the hypervisor (single-purpose).	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR 5.4	Application partitioning	Confirm strong workload isolation: VM/network segmentation (separate management/vMotion/storage/VM VLANs), resource pools, and — for high assurance — separate clusters per zone so a compromise is contained. **Ext. tools:** Network/portgroup + resource-pool review; cluster zoning.	Workloads/roles partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1	Audit log accessibility	Persistent logs + remote syslog to SIEM; vCenter events/alarms monitored; Skyline/health checks. Confirm logs are retained and reach the SIEM. **Ext. tools:** SIEM check; syslog listener.	Logs retained + forwarded; host/vCenter monitoring active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial of service protection	VM resource limits/shares/reservations and admission control prevent one VM starving the host; monitor host CPU/mem/datastore. **Ext. tools:** PowerCLI resource review; vCenter performance.	Resource controls prevent exhaustion; host stays available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Back up host config (`vim-cmd hostsvc/firmware/backup_config` / `Get-VMHostFirmware -BackupConfiguration`) and vCenter; test restore on a spare host. **Ext. tools:** Config backup export; lab restore.	Host config + vCenter backed up; restore tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply/verify the vSphere ESXi STIG / Security Config Guide via **Host Profiles** compliance or a PowerCLI audit script; document deviations. **Ext. tools:** STIG/SCAP; Host Profile compliance.	Host matches the STIG/SCG baseline; deviations documented.	
SR/CR 7.7	Least functionality	Disable SSH/ESXi Shell, **MOB** (`Config.HostAgent.plugins.solo.enableMob = false`), CIM, and unused services; Lockdown Mode; remove unneeded VIBs. **Ext. tools:** Nmap (open services); `Get-AdvancedSetting -Name Config.HostAgent.plugins.solo.enableMob`	Only required services enabled; MOB/SSH/Shell off; lockdown on.	
SR/CR 7.8	Component inventory	Capture version, hardware, and VIBs: `esxcli system version get`, `esxcli hardware platform get`, `esxcli software vib list`. **Ext. tools:** vCenter inventory; PowerCLI export.	Complete version/hardware/VIB inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
PowerCLI (VMware.PowerCLI)	Effective host security state (most rows)	`Get-VMHost | Get-AdvancedSetting -Name Security.*`; `Get-VMHostService`, `Get-VMHostFirewallException`, `Get-VIPermission`.	Read-only get; authorized account.
ESXCLI	Native host config query (many)	`esxcli system ntp get`, `esxcli software acceptance get`, `esxcli network firewall ruleset list`, `esxcli software vib list`.	Read-only.
DISA vSphere ESXi 8 STIG + vSphere Security Config Guide	Baseline compliance (all)	Evaluate the host against the STIG/SCG (STIG Viewer + PowerCLI audit scripts); primary pass/fail evidence.	Authorized; read-only audit.
SCAP / compliance scanner	Automated baseline check (all)	Run the vSphere SCAP content or a PowerCLI compliance script; export results.	Authorized scan account.
Nmap	Port/service exposure & segmentation (1.1, 1.13, 5.x, 7.7)	`nmap -sT -p 22,443,902,5989,8000 -T2` ; scan by segment; confirm 22 closed and mgmt isolated.	Tune timing on production.
sslscan / testssl.sh	TLS strength (4.3)	`sslscan :443`; confirm TLS1.2/1.3 + strong ciphers, no TLS1.0/1.1.	Read-only.
Wireshark / tcpdump	Comm integrity & NTP (2.11, 3.x)	SPAN/tap; confirm mgmt is TLS and inspect NTP/vMotion encryption.	Passive; SPAN/tap only.
Syslog server / SIEM	Audit forwarding & monitoring (2.8, 6.x)	Confirm host syslog + audit records arrive; trigger a test event.	Coordinate with SIEM team.
Nessus / OpenVAS	Known-CVE scan (3.x, general)	Authenticated scan for ESXi CVEs; cross-check VMware VMSA advisories.	ISOLATED/authorized.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.